

# Pentest: Web Application

## Target Information

Target IP: 10.49.133.18

## Reconnaissance

### Nmap

```
sudo nmap -sS -sC -sV -A -O 10.49.133.182 -T5 --min-rate 2000
0
sudo: unable to resolve host ip-10-49-89-83: Name or service
not known
Starting Nmap 7.80 ( https://nmap.org ) at 2026-05-30 09:54 B
ST
mass_dns: warning: Unable to open /etc/resolv.conf. Try using
--system-dns or specify valid servers with --dns-servers
mass_dns: warning: Unable to determine any DNS servers. Rever
se DNS is disabled. Try using --system-dns or specify valid s
ervers with --dns-servers
Nmap scan report for 10.49.133.182
Host is up (0.00035s latency).
Not shown: 996 closed ports
PORT      STATE SERVICE VERSION
22/tcp    open  ssh      OpenSSH 9.6p1 Ubuntu 3ubuntu13.5 (Ubun
tu Linux; protocol 2.0)
80/tcp    open  http      Apache httpd 2.4.58 ((Ubuntu))
| http-cookie-flags:
|   /:
|     PHPSESSID:
|_      httponly flag not set
|_http-server-header: Apache/2.4.58 (Ubuntu)
|_http-title: RecruitX - Home
3306/tcp  open  mysql     MySQL (unauthorized)
```

```
8080/tcp open  http      Apache httpd 2.4.58 ((Ubuntu))
|_http-open-proxy: Proxy might be redirecting requests
|_http-server-header: Apache/2.4.58 (Ubuntu)
|_http-title: Apache2 Ubuntu Default Page: It works
Aggressive OS guesses: Linux 3.1 (95%), Linux 3.2 (95%), AXIS
210A or 211 Network Camera (Linux 2.6.17) (94%), Linux 3.10 -
3.13 (93%), Linux 3.8 (93%), ASUS RT-N56U WAP (Linux 3.4) (9
3%), Linux 3.16 (93%), Adtran 424RG FTTH gateway (92%), Linux
2.6.32 (92%), Linux 2.6.39 - 3.2 (92%)
No exact OS matches for host (test conditions non-ideal).
Network Distance: 1 hop
Service Info: OS: Linux; CPE: cpe:/o:linux:linux_kernel
```

TRACEROUTE (using port 443/tcp)

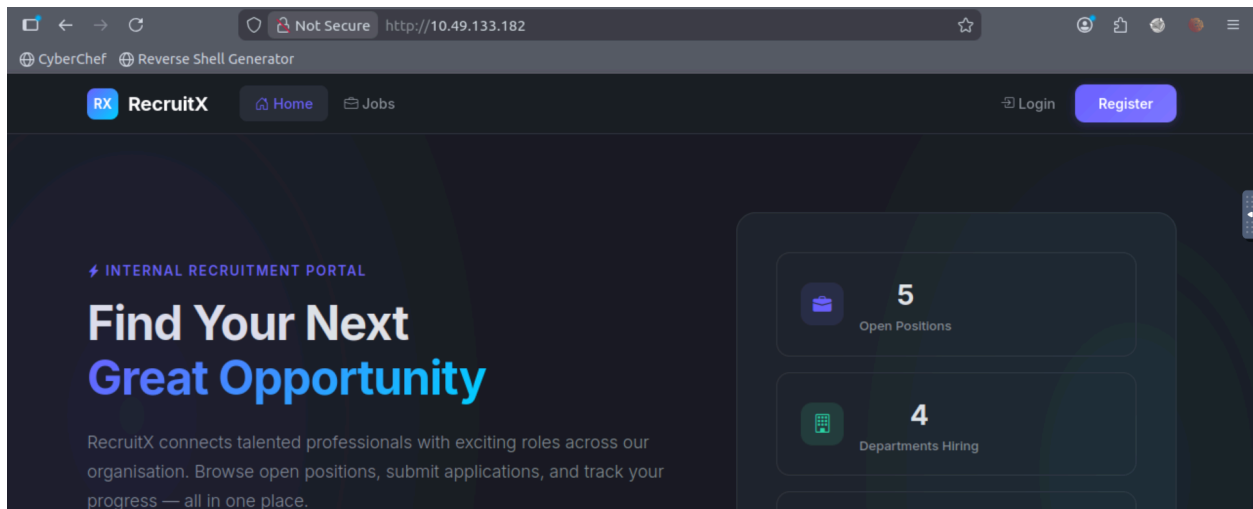
| HOP | RTT     | ADDRESS       |
|-----|---------|---------------|
| 1   | 0.35 ms | 10.49.133.182 |

Number Open ports 4

```
22/tcp  open  ssh      OpenSSH 9.6p1 Ubuntu 3ubuntu13.5 (Ubun
tu Linux; protocol 2.0)
80/tcp  open  http     Apache httpd 2.4.58 ((Ubuntu))
3306/tcp open  mysql    MySQL (unauthorized)
8080/tcp open  http     Apache httpd 2.4.58 ((Ubuntu))
```

Checking out the port number 80 HTTP for Apache Web Application

The site : http://10.49.133.182:80



The site seems to be like a Job finding Application. Going to enumerate the site using tool gobuster to find hidden directory.

## Enumeration

Using the Gobuster

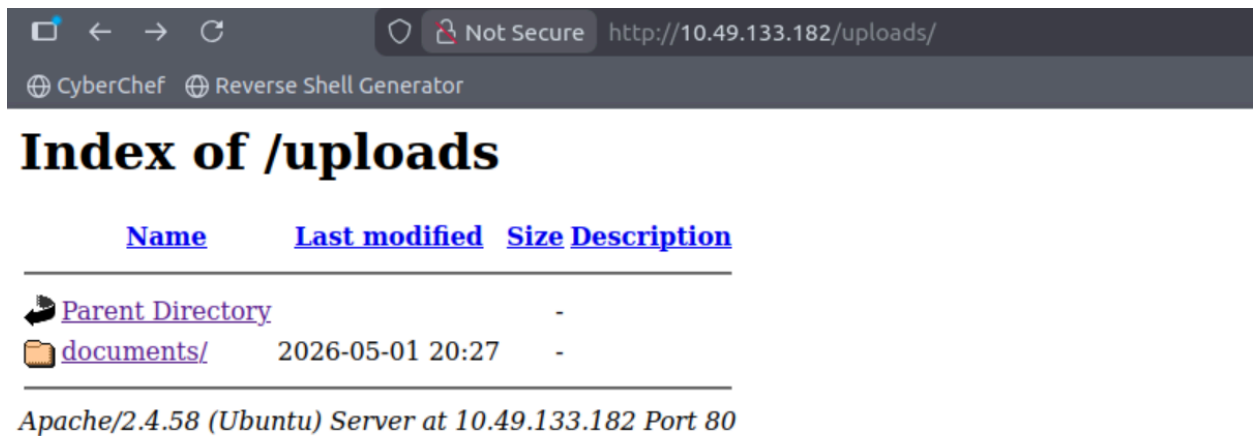
```
[+] Url: http://10.49.133.182/
[+] Method: GET
[+] Threads: 50
[+] Wordlist: /usr/share/wordlists/SecLists/Discovery/Web-Content/directory-list-2.3-medium.txt
[+] Negative Status codes: 404
[+] User Agent: gobuster/3.6
[+] Timeout: 10s
```

```
/uploads (Status: 301) [Size: 316] [--> http://10.49.133.182/uploads/]
/data (Status: 403) [Size: 278]
/admin (Status: 301) [Size: 314] [--> http://10.49.133.182/admin/]
/test (Status: 200) [Size: 705]
```

```
/includes      (Status: 301) [Size: 317] [--> http://10.49.133.182/includes/]
/api           (Status: 301) [Size: 312] [--> http://10.49.133.182/api/]
/config        (Status: 301) [Size: 315] [--> http://10.49.133.182/config/]
/server-status (Status: 403) [Size: 278]
```

Checking out the each directory manually

1. `/uploads` → it takes to index page of the application



The screenshot shows a web browser window with the address bar displaying `http://10.49.133.182/uploads/`. The browser's security status is "Not Secure". The page title is "Index of /uploads". Below the title is a table with the following columns: "Name", "Last modified", "Size", and "Description". The table contains two entries: "Parent Directory" with a back arrow icon and "documents/" with a folder icon, both showing a last modified date of "2026-05-01 20:27" and a size of "-". At the bottom of the page, it says "Apache/2.4.58 (Ubuntu) Server at 10.49.133.182 Port 80".

| Name                             | Last modified    | Size | Description |
|----------------------------------|------------------|------|-------------|
| <a href="#">Parent Directory</a> | -                | -    |             |
| <a href="#">documents/</a>       | 2026-05-01 20:27 | -    |             |

Apache/2.4.58 (Ubuntu) Server at 10.49.133.182 Port 80

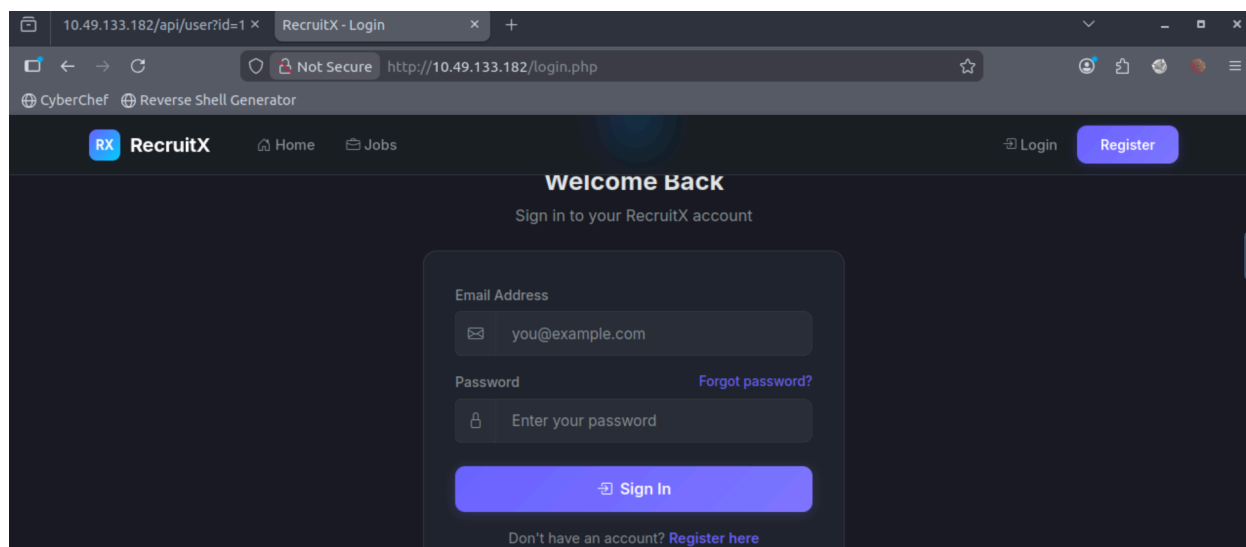
2. `/data` → this page was forbidden

## Forbidden

You don't have permission to access this resource.

Apache/2.4.58 (Ubuntu) Server at 10.49.133.182 Port 80

3. `/admin` → Login required to access the admin directory



4. `/test` → developer felt the code

```
<VirtualHost *:80>
    ServerName recruitx.thm
    ServerAlias *

    DocumentRoot /var/www/recruitx

    <Directory /var/www/recruitx>
        Options +Indexes +FollowSymLinks
        AllowOverride All
        Require all granted
    </Directory>

    # Ensure .phtml is processed as PHP (INTENTIONAL VULN)
    # This is often already configured by default on Ubuntu
    <FilesMatch "\.phtml$">
        SetHandler application/x-httpd-php
    </FilesMatch>
```

```
# Block access to data directory
<Directory /var/www/recruitx/data>
    Require all denied
</Directory>

ErrorLog ${APACHE_LOG_DIR}/recruitx_error.log
CustomLog ${APACHE_LOG_DIR}/recruitx_access.log combined
</VirtualHost>
```

5. `/includes` → Application style pages

## Index of /includes

| <u>Name</u>                                                                                                                 | <u>Last modified</u> | <u>Size</u> | <u>Description</u> |
|-----------------------------------------------------------------------------------------------------------------------------|----------------------|-------------|--------------------|
|  <a href="#">Parent Directory</a>        |                      | -           |                    |
|  <a href="#">bootstrap-icons.min.css</a> | 2026-03-30 08:56     | 84K         |                    |
|  <a href="#">bootstrap.bundle.min.js</a> | 2026-03-30 09:05     | 79K         |                    |
|  <a href="#">bootstrap.min.css</a>       | 2026-03-30 08:56     | 227K        |                    |
|  <a href="#">fonts.css</a>               | 2026-03-30 08:53     | 2.1K        |                    |
|  <a href="#">fonts/</a>                  | 2026-03-30 09:03     | -           |                    |
|  <a href="#">footer.php</a>              | 2026-03-30 09:06     | 257         |                    |
|  <a href="#">header.php</a>              | 2026-03-30 09:04     | 14K         |                    |

*Apache/2.4.58 (Ubuntu) Server at 10.49.133.182 Port 80*

6. `/config` → in the index where the database where stored but can't access them

Browser address bar: <http://10.49.133.182/config/> (Not Secure)

CyberChef Reverse Shell Generator

## Index of /config

| Name                             | Last modified    | Size | Description |
|----------------------------------|------------------|------|-------------|
| <a href="#">Parent Directory</a> |                  | -    |             |
| <a href="#">db.php</a>           | 2026-03-24 07:57 | 7.5K |             |

Apache/2.4.58 (Ubuntu) Server at 10.49.133.182 Port 80

7. `/api` → The api was exposed

Browser address bar: <http://10.49.133.182/api/>

CyberChef Reverse Shell Generator

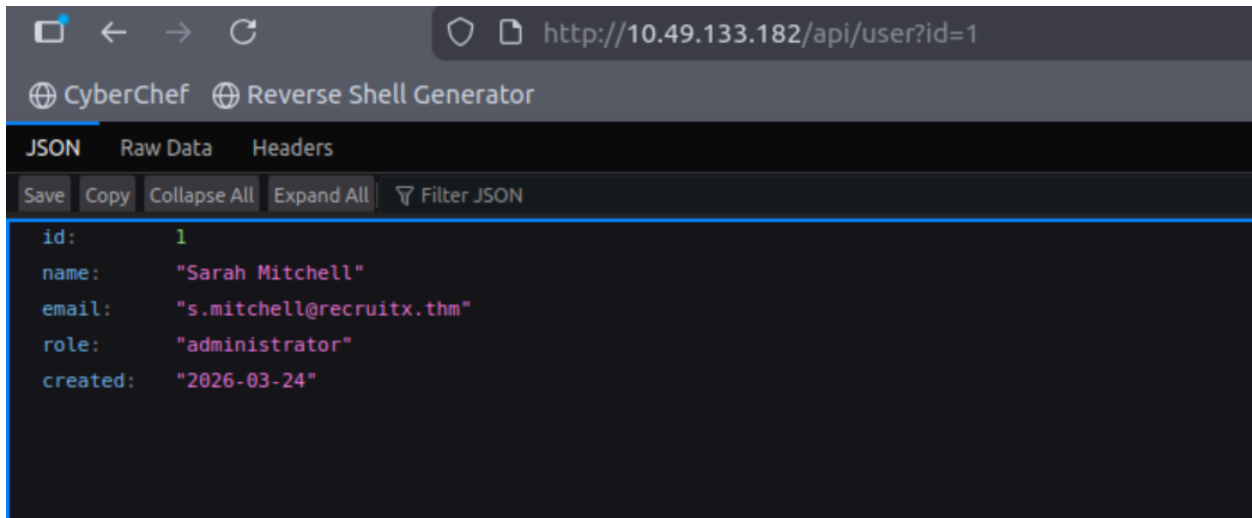
JSON Raw Data Headers

Save Copy Collapse All Expand All Filter JSON

```
▼ endpoints:  
  0:      "/api/user"  
  1:      "/api/jobs"  
  2:      "/api/applications"
```

Using the exposed api we can perform IDOR , where we can see the user detail without accessing them.

- Using the /api/user?id=1

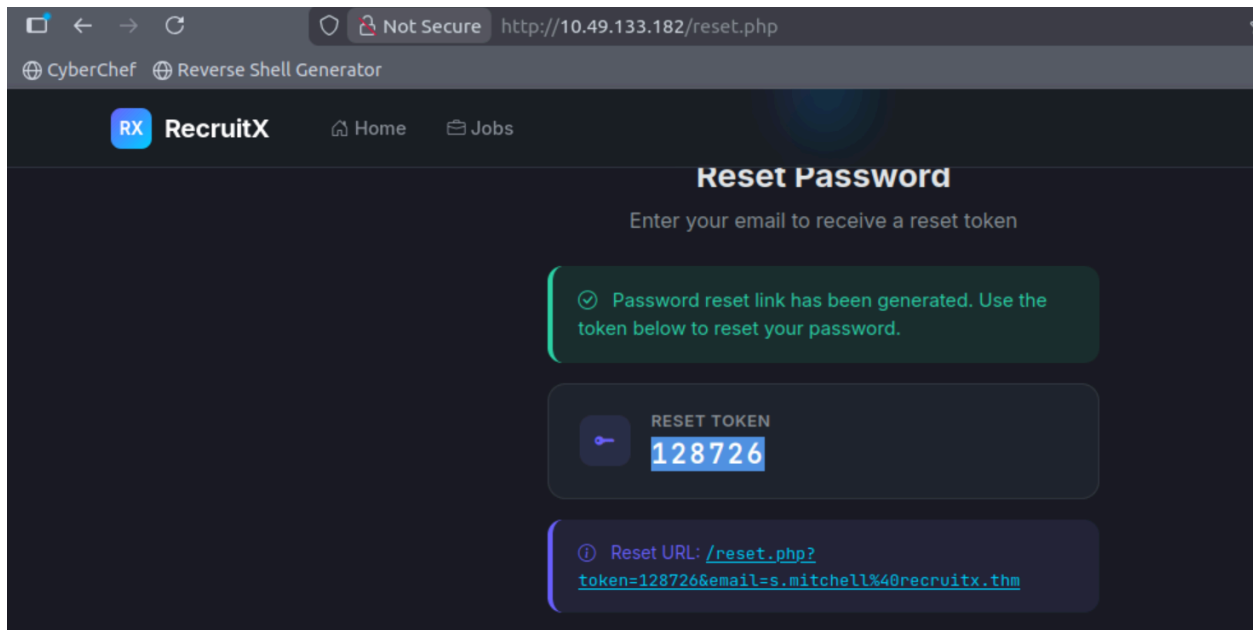


The id=1 "Sarah Mitchell" exposed the user role was the administrator

```
id 1
name "Sarah Mitchell"
email "s.mitchell@recruitx.thm"
role "administrator"
created "2026-03-24"
```

Now lets login by giving the forgot password





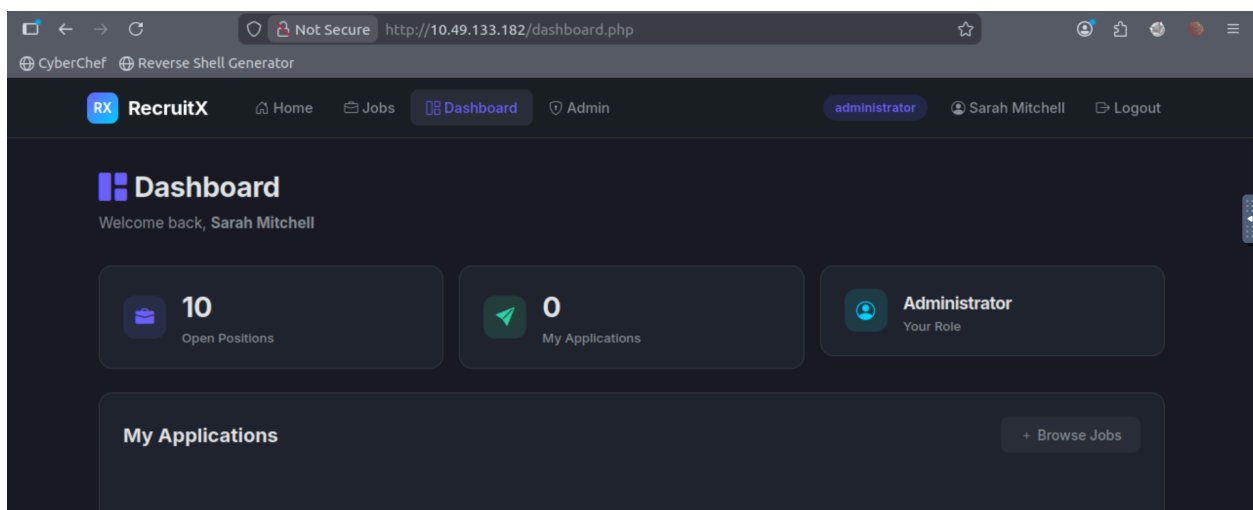
The reset token gave and the password resetting the new password link given without any proper MFA by the server.

Now resetting the password to `tester1`

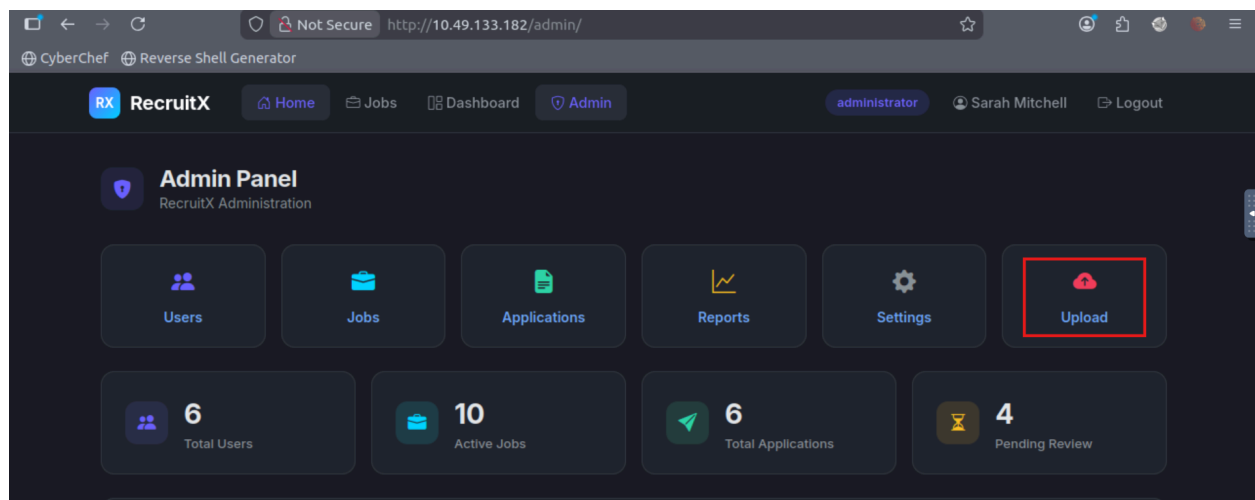
Now we can login as a admin user using the credentials

- Email: `s.mitchell@recruitx.thm`
- password: `tester1`

**Successfully logged in as Administrator**

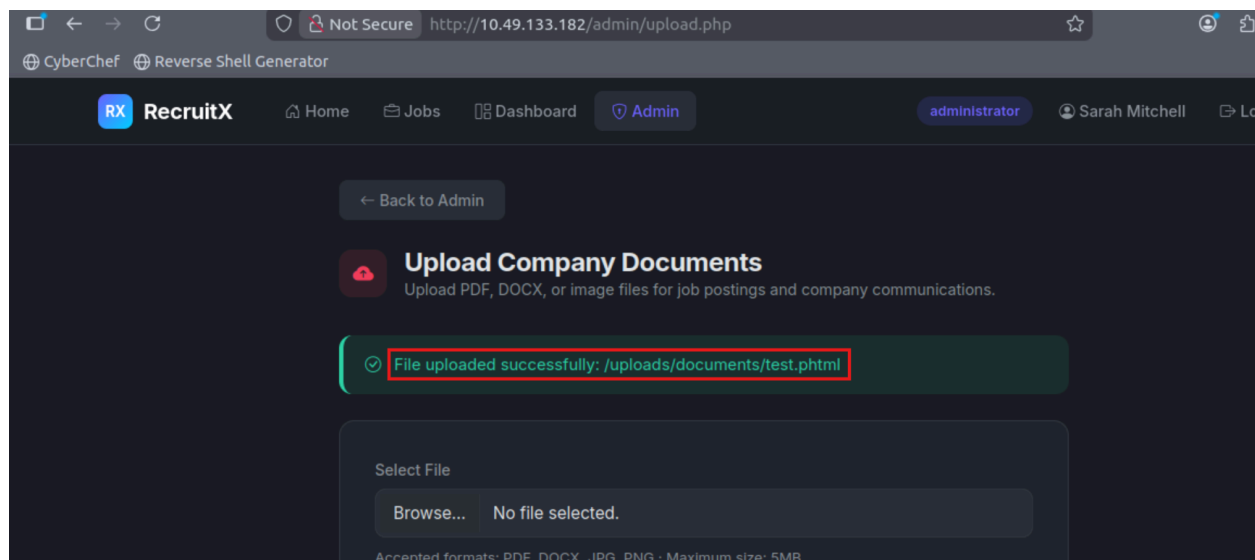


In the Admin Dashboard we can see the upload option where we can upload file, We can also upload a malicious .php code in order to compromised the admin and user database by performing Remote code execution.

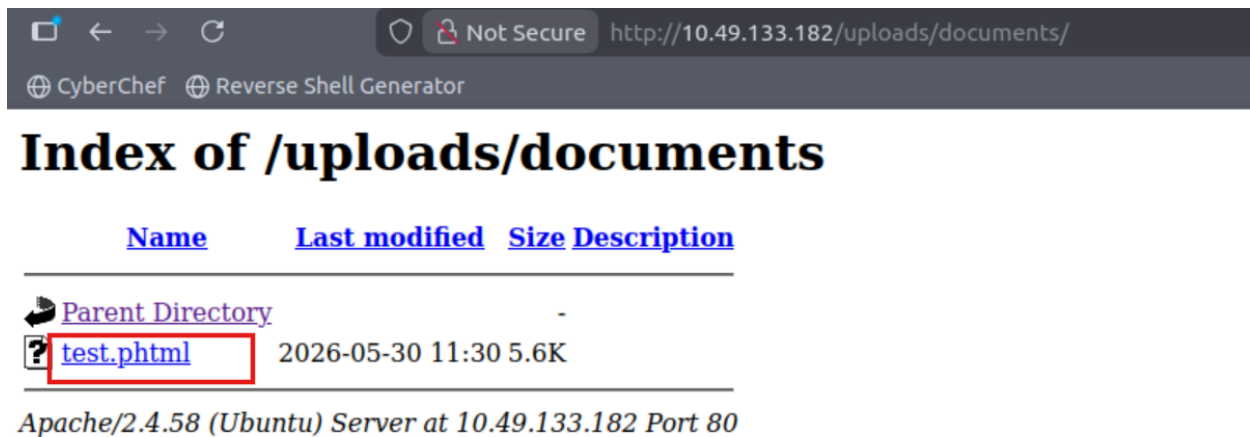


Took a reverse shell php code form the pentest monkey

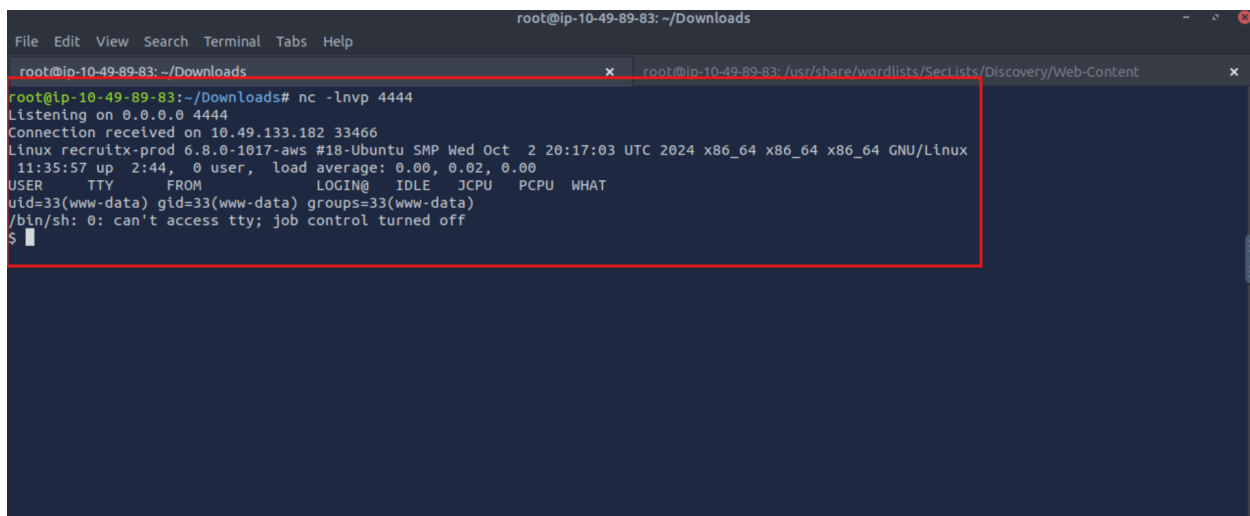
The Reverse shell php: <https://github.com/pentestmonkey/php-reverse-shell/blob/master/php-reverse-shell.php>



Uploaded the .phtml reverse shell code successfully, Now we can check the directory where the file is been stored.



I have setup the listener using the tool netcat on port 4444, By clicking the file in the /uploads directory, We have successfully gained access to the system.



## Basic Commands to know about the environment

- whoami → www-data

- hostname → recruitx-prod

## Finding the flag

```
find / -name flag.txt 2>/dev/null
```

## The Flag

```
THM{ch41n3d_vulns_4r3_d3v4st4t1ng}
```

## Remediation

| Vulnerability                                | Severity | Remediation                                                                                                                                                                                     |
|----------------------------------------------|----------|-------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------|
| IDOR on user profiles and API                | High     | Implement server-side authorisation checks on every request. Verify that the authenticated user has permission to access the requested resource.                                                |
| Password reset token exposed in the response | Critical | Send reset tokens exclusively via email. Display only a generic confirmation message on the page. Use cryptographically random tokens of at least 32 characters.                                |
| Incomplete file extension blocklist          | Critical | Use an allowlist rather than a blocklist. Only permit specific, expected extensions. Validate file content (MIME type) in addition to the extension. Store uploaded files outside the web root. |
| API endpoint disclosure                      | Medium   | Remove the API index endpoint or restrict it to authenticated administrators. Do not expose internal route structures to unauthenticated users.                                                 |

## MITRE ATT&CK Mapping

### 1. Reconnaissance

- **T1046 – Network Service Discovery**

Reason: Used Nmap to discover open ports (SSH, HTTP, MySQL, Apache).

---

## 2. Discovery

- **T1083 – File and Directory Discovery**

Reason: Used Gobuster to discover hidden directories such as `/admin`, `/uploads`, `/api`, `/config`, and `/test`.

- **T1592.002 – Gather Victim Host Information: Software**

Reason: Identified Apache version, virtual host configuration, and file upload handling from the exposed developer test page.

---

## 3. Initial Access

- **T1190 – Exploit Public-Facing Application**

Reason: Exploited IDOR vulnerability and insecure password reset functionality to gain administrator account access.

---

## 4. Credential Access

- **T1556 – Modify Authentication Process**

Reason: Abused flawed password reset workflow to set a new password for the administrator account.

- **T1078 – Valid Accounts**

Reason: Logged in as a legitimate administrator using the newly reset credentials.

---

## 5. Execution

- **T1059.003 – Command and Scripting Interpreter: PHP**

Reason: Uploaded and executed a malicious PHP reverse shell on the web server.

---

## 6. Persistence / Execution

- **T1505.003 – Server Software Component: Web Shell**

Reason: Uploaded a `.phtml` web shell through the administrator upload functionality.

---

## 7. Command and Control

- **T1071 – Application Layer Protocol**

Reason: Established reverse shell communication between the compromised server and attacker machine.

---

## 8. Discovery

- **T1082 – System Information Discovery**

Reason: Enumerated host information using commands such as `hostname`.

- **T1033 – System Owner/User Discovery**

Reason: Identified the current user context ( `www-data` ) using `whoami`.

- **T1083 – File and Directory Discovery**

Reason: Used the `find` command to locate the flag file on the system.

---

## 9. Collection

- **T1005 – Data from Local System**

Reason: Accessed and retrieved the contents of `flag.txt`.

# DONE BY

# RUTHRAN-SEC